



**IN RE: THE HONGKONG AND
SHANGHAI BANKING
CORPORATION LIMITED (HSBC)**

NPC BN 18-203

X-----X

ORDER

Before the Commission is the Post-Breach Report dated 10 May 2022 (Post-Breach Report) submitted by The Hongkong and Shanghai Banking Corporation Limited (HSBC) in compliance with the Order dated 21 April 2022 (Order) of the Commission, through its Complaints and Investigation Division (CID).¹

On 20 October 2018, Information Express Service (INFORMEX), HSBC's third-party courier company, received a report that its messenger had lost the mail packs assigned to him.² The messenger clarified that the cause was due to the mail packs falling off his bicycle due to the bad weather at that time since he decided to put a raincoat over the bundle of mail packs that he had tied down to his bicycle.³ This was the reason why the messenger did not notice that the bundle of mail packs had already fallen off his bicycle and got lost. The messenger also stated that he "retraced his route to locate the mail packs without success."⁴

On 23 October 2018, HSBC alleged that the messenger filed an official report to the Barangay Hall of Maysilo Malabon on the lost mail packs.⁵

¹ Post Breach Report of Hongkong and Shanghai Banking Corporation Limited, dated 10 May 2022.

² Initial Report (Data Breach Due to Lost Mail Packs dated 29 October 2018) of Hongkong and Shanghai Banking Corporation Limited, dated 31 October 2018, at p. 2.

³ *Id.*

⁴ *Id.*

⁵ *Id.*

On 26 October 2018, the messenger informed his superiors in INFORMEX regarding the loss of mail packs.⁶

On 29 October 2018, HSBC indicated that it only became aware of the incident after it had received a notification from INFORMEX.⁷ Further, HSBC alleged that they required INFORMEX to supply the details and clarification.⁸

On 31 October 2018, HSBC notified the Commission regarding the said incident.⁹

In its Initial Report, HSBC claimed that there were forty-eight (48) individual customers affected by the incident.¹⁰ The mail packs that were lost involved fifty (50) credit card statements and three (3) collection letters that contained personal information such as customer name and address.¹¹ HSBC stated that they shall inform the credit card holders in “due course”.¹²

HSBC claims that “it has the necessary controls in place to manage the said risk brought by the incident.”¹³ Moreover, HSBC asserts that the control measures are in place to prevent “unauthorized use of affected credit card account” and that their contact center is “ready to attend to any concerns” relating to the incident.¹⁴

As to the measures HSBC took to address the incident, they claimed the following:

1. Review of accounts for unusual transactions from the date of the incident and then monitoring for any unusual transaction until credit card gets blocked.
2. Blocking and replacement of credit card to be done. This shall prevent unauthorized use of credit card and fraud.

⁶ Full Breach Report (In Compliance with the Order dated 07 October 2020) of Hongkong and Shanghai Banking Corporation Limited, dated 23 October 2020, at p. 1.

⁷ Initial Report (Data Breach Due to Lost Mail Packs dated 29 October 2018) of Hongkong and Shanghai Banking Corporation Limited, dated 31 October 2018, at p. 2.

⁸ *Id.*

⁹ *Id.*

¹⁰ *Id.*

¹¹ Initial Report (Data Breach Due to Lost Mail Packs dated 29 October 2018) of Hongkong and Shanghai Banking Corporation Limited, dated 31 October 2018, at p. 2.

¹² *Id.*

¹³ *Id.*

¹⁴ *Id.*

3. Statement and letters to be reprinted and re-dispatched to ensure that HSBC's service still gets delivered to the affected customers.
4. HSBC's contact center was briefed about the matter and was given the names of the affected customer for proper handling.
5. Vendor was counseled at length to emphasize importance of safekeeping documents containing customer information. Root cause of the incident to be analyzed and process and controls to be enhanced to avoid recurrence.¹⁵

On 08 October 2020, the Complaints and Investigation Division (CID) of the National Privacy Commission issued an Order requiring HSBC to submit its Full Breach Report within fifteen (15) days from receipt.¹⁶

On 23 October 2020, HSBC submitted its Compliance to the said Order dated 08 October 2020.¹⁷ In HSBC's Compliance, it claimed that "the information in this particular incident is neither Sensitive Personal Information nor necessarily in the nature that can be used to identity fraud."¹⁸ Furthermore, HSBC added that the detailed personal information involved are the following:

Credit Card Statement

- i. Name;
- ii. Address;
- iii. Credit Card Number/Credit Card Account Number;
- iv. Transaction History; and
- v. Amount Due, Minimum Required payment, and other related information.

Demand Letter

- i. Name;
- ii. Address;
- iii. Credit Card Number/Credit Card Account Number
- iv. Amount Due and other related information¹⁹

¹⁵ Initial Report (Data Breach Due to Lost Mail Packs dated 29 October 2018) of Hongkong and Shanghai Banking Corporation Limited, dated 31 October 2018, at p. 2-3.

¹⁶ *In re: The Hongkong and Shanghai Banking Corporation Limited (HSBC)*, NPC BN 18-203, Order 08 October 2020.

¹⁷ Full Breach Report (In Compliance with the Order dated 07 October 2020) of Hongkong and Shanghai Banking Corporation Limited, dated 23 October 2020.

¹⁸ Full Breach Report (In Compliance with the Order dated 07 October 2020) of Hongkong and Shanghai Banking Corporation Limited, dated 23 October 2020, at p. 3.

¹⁹ *Id.*

To add, HSBC claimed that its Customer Contact Centre Team already reached out to the affected data subjects via call-outs and Short Messaging Service (SMS) to inform them on the incident.²⁰ HSBC likewise added that the credit cards were blocked and replaced to mitigate the exposure of any unauthorized transactions that may take place.²¹ Moreover, HSBC declared that it directed the Contact Centre Team to change the set of questions it uses to verify the identity of the affected customers to prevent identity fraud.²²

As to the organizational measures, HSBC stated that it required its service providers to train its employees on the proper handling of information consistent with HSBC's data protection policies.²³ Moreover, HSBC added that it designates a "Third Party Engagement Manager (TPEM)" to manage the bank's relationship with the service providers.²⁴

On 21 April 2022, the CID issued an Order requiring HSBC to submit its Post-Breach Report within fifteen (15) days from receipt.²⁵

On 10 May 2022, HSBC submitted its Post-Breach Report and its corresponding annexes reiterating their previous discussions and measures undertaken.²⁶ HSBC asserted that its notification involved is voluntary and not a mandatory one because the information involved in this is neither sensitive personal information nor necessarily in the nature that be used to enable identity fraud.²⁷ Moreover, HSBC claimed that "the voluntary notification was done to show its good faith, promote transparency and candor and in the spirit of receiving guidance from this Honorable Commission."²⁸

²⁰ Full Breach Report (In Compliance with the Order dated 07 October 2020) of Hongkong and Shanghai Banking Corporation Limited, dated 23 October 2020, at p. 3.

²¹ *Id.*

²² *Id.*

²³ Full Breach Report (In Compliance with the Order dated 07 October 2020) of Hongkong and Shanghai Banking Corporation Limited, dated 23 October 2020, at p. 5.

²⁴ *Id.*

²⁵ *In re: The Hongkong and Shanghai Banking Corporation Limited (HSBC)*, NPC BN 18-203, Order (To submit Post-Breach Report), dated 21 April 2022.

²⁶ Post Breach Report of Hongkong and Shanghai Banking Corporation Limited, dated 10 May 2022.

²⁷ Post Breach Report of Hongkong and Shanghai Banking Corporation Limited, dated 10 May 2022, at p. 1.

²⁸ *Id.*

In addition, in its Post-Breach Report, HSBC claims that:

Considering the nature of the breach involved **does not require mandatory notification** to the Commission or the data subjects under this Honorable Commission's Memorandum Circular 16-03, HSBC carried out communication which among others, informed the affected customers that there may be a possible compromise to their credit card and that it would be best to block and replace the card to protect their account.

In any event, security measures have been implemented and applied since the breach was reasonably believed to have occurred including measures that would prevent use of data by any person not authorized to access it. Moreover, measures have taken to ensure the risk of harm to the affected customers will not materialize. As an added precaution, HSBC informed the customer of the recommended option to carry out the blocking and replacement of credit cards to mitigate risk. A copy of the list of the Consolidated Report of the reach-out's including information on the block and replacement of cards is hereto attached and made an integral part hereof as **Annex "2"**. Note that only customer opted not to have his/her card undergo block and replacement given the security in place.²⁹

Upon evaluation of HSBC's Post-Breach Report, the Commission finds that the PIC has not sufficiently complied with NPC Circular No. 16-03 (Personal Data Breach Management).

In HSBC's Initial Report, they notified the Commission regarding an incident that an employee of their third party courier, INFORMEX, had lost the mail packs assigned to him.³⁰ In addition, HSBC claimed that there were forty-eight (48) data subjects affected by the incident.

Section 11 of NPC Circular No. 16-03 provides the conditions for mandatory breach notification:

SECTION 11. *When notification is required.* Notification shall be required upon knowledge of or **when there is reasonable belief by the personal information controller or personal**

²⁹ Post Breach Report of Hongkong and Shanghai Banking Corporation Limited, dated 10 May 2022, at p. 3.

³⁰ Initial Report (Data Breach Due to Lost Mail Packs dated 29 October 2018) of Hongkong and Shanghai Banking Corporation Limited, dated 31 October 2018, at p. 2.

information processor that a personal data breach requiring notification has occurred, under the following conditions:

- A. The **personal data involves sensitive personal information or any other information that may be used to enable identity fraud.**

For this purpose, “**other information**” shall include, but not be limited to: **data about the financial or economic situation of the data subject**; usernames, passwords and other login data; biometric data; copies of identification documents, licenses or unique identifiers like Philhealth, SSS, GSIS, TIN number; or other similar information, which may be made the basis of decisions concerning the data subject, including the grant of rights or benefits.

- B. There is **reason to believe that the information may have been acquired by an unauthorized person**; and
- C. The personal information controller or the Commission believes **that the unauthorized acquisition is likely to give rise to a real risk of serious harm to any affected data subject.**³¹ (Emphasis supplied)

In HSBC’s Full Breach Report, it stated that the lost mail packs contained the following information:

Credit Card Statement

- i. Name;
- ii. Address;
- iii. Credit Card Number/Credit Card Account Number;
- iv. Transaction History; and
- v. Amount Due, Minimum Required payment, and other related information.

Demand Letter

- i. Name;
- ii. Address;
- iii. Credit Card Number/Credit Card Account Number
- iv. Amount Due and other related information³²

³¹ National Privacy Commission, Personal Data Breach Management, NPC Circular No. 16-03, rule V, § 11.

³² Full Breach Report (In Compliance with the Order dated 07 October 2020) of Hongkong and Shanghai Banking Corporation Limited, dated 23 October 2020, at p. 3.

In this case, the information involved in the Credit Card Statement and Demand Letter particularly, the Credit Card Number/Credit Card Account Number, Transaction History and Amount Due is categorized within the purview of “sensitive personal information and any other information that, under the circumstances, may be used to enable identity fraud”³³ provided by Section 11 (a) of NPC Circular 16-03. The credit card number/credit card account number are attributed under “other information” as specified in second paragraph of Section 11 (a), given that it pertains to the financial and economic situation of the data subject.³⁴ To reiterate, the names and addresses coupled with the credit card number and credit card account numbers involved are considered as information that, under the circumstances, may be used to enable identity fraud. Thus, the first requisite is present in this case.

For the second requisite, HSBC stated that the messenger claimed that he “retraced his route to locate the mail packs without success.”³⁵ Since the mail packs were lost along the route and failed to locate the lost mail packs, there is reason to believe that the Credit Card Statements and Demand Letters contained in the said mail packs may have been acquired by an unauthorized person. Moreover, the incident involves an “availability breach” due to the loss of mail packs by the messenger of INFORMEX.³⁶ Under NPC Circular 16-03, there is an availability breach when “the breach resulted from loss, accidental, or unlawful destruction of personal data.”³⁷

Lastly, since the nature of information involved pertains to the financial information and economic situation of the data subject contained in the Credit Card Statement and Demand Letter of forty-eight (48) affected data subjects, the loss of these likely gives rise to a real risk of serious harm to the affected data subjects.

³³ An Act Protecting Individual Personal Information in Information and Communications Systems in the Government and the Private Sector, Creating for This Purpose a National Privacy Commission, and for Other Purposes [Data Privacy Act of 2012], Republic Act No. 10173, chapter V, § 20 (f) (2012).

³⁴ National Privacy Commission, Personal Data Breach Management, NPC Circular No. 16-03, rule V, § 11 (a).

³⁵ Initial Report (Data Breach Due to Lost Mail Packs dated 29 October 2018) of Hongkong and Shanghai Banking Corporation Limited, dated 31 October 2018, at p. 2.

³⁶ Initial Report (Data Breach Due to Lost Mail Packs dated 29 October 2018) of Hongkong and Shanghai Banking Corporation Limited, dated 31 October 2018, at p. 2.

³⁷ National Privacy Commission, Personal Data Breach Management, NPC Circular No. 16-03, rule I, § 3 (F).

To add, in HSBC's Post Breach Report, it claimed that "the information in this particular incident is neither Sensitive Personal Information nor necessarily in the nature that can be used to identity fraud."³⁸ However, this contradicts the actions done by HSBC, particularly, the blocking and replacement of the cards in order for the affected data subjects to protect their accounts. Through these acts it seems that HSBC believes that the incident may lead to identity fraud.

Given the unwarranted exposure to unauthorized persons due to the loss of mail packs in the streets containing the sensitive personal information and other information that, under the circumstances, may enable identity fraud particularly the financial information of the affected data subjects, there is a belief that the incident likely gives rise to a real risk of serious harm to the affected data subjects. Hence, the third requisite is present.

Since all the requirements were satisfied, the incident falls under mandatory notification to the Commission under Section 11 of NPC Circular No. 16-03.

Therefore, it is the obligation of HSBC, as Personal Information Controller (PIC), to immediately notify the affected data subjects in order for them to take necessary precautions or to protect themselves against the possible effects of the breach.³⁹

It must be noted that HSBC averred that its Customer Contact Centre Team already reached out to the affected data subjects via call-outs and Short Messaging Service (SMS) to inform them of the incident.⁴⁰ However, the notification done by HSBC does not conform with NPC Circular 16-03.

³⁸ Post Breach Report of Hongkong and Shanghai Banking Corporation Limited, dated 10 May 2022.

³⁹ National Privacy Commission, Personal Data Breach Management, NPC Circular No. 16-03, rule V, § 18 (A).

⁴⁰ Full Breach Report (In Compliance with the Order dated 07 October 2020) of Hongkong and Shanghai Banking Corporation Limited, dated 23 October 2020, at p. 3.

Section 18 (C) and (D) of NPC Circular No. 16-03 states:

Section 18. *Notification of Data Subjects.* The personal information controller shall notify the data subjects affected by a personal data breach, subject to the following procedures:

...

C. *Content of Notification.* The notification shall include, but not be limited to:

1. nature of the breach;
2. personal data possibly involved;
3. measures taken to address the breach;
4. measures taken to reduce the harm or negative consequences of the breach;
5. representative of the personal information controller, including his or her contact details, from whom the data subject can obtain additional information regarding the breach; and
6. any assistance to be provided to the affected data subjects.

Where it is not possible to provide the foregoing information all at the same time, they may be provided in phases without undue delay.

D. Form. **Notification of affected data subjects shall be done individually, using secure means of communication, whether written or electronic.** The personal information controller shall take the necessary steps to ensure the proper identity of the data subject being notified, and to safeguard against further unnecessary disclosure of personal data. The personal information controller shall establish all reasonable mechanisms to ensure that all affected data subjects are made aware of the breach: Provided, that where individual notification is not possible or would require a disproportionate effort, the personal information controller may seek the approval of the Commission to use alternative means of notification, such as through public communication or any similar measure through which the data subjects are informed in an equally effective manner: Provided further, that the personal information controller shall establish means through which the data subjects can exercise their rights and obtain more detailed information relating to the breach.⁴¹

⁴¹ National Privacy Commission, Personal Data Breach Management, NPC Circular No. 16-03, rule V, § 18 (C) and (D).

The incident only involved forty-eight data subjects affected by the loss of the mail packs and the PIC could have attached their individual notification in their submissions.⁴² In their Post Breach Report, HSBC stated that “A copy of the list of the Consolidated Report of the reach-out’s including information on the block and replacement of cards is hereto attached and made an integral part hereof as **Annex “2”**.”⁴³ However, upon careful review of the submissions of HSBC, the submitted document does not provide for the required contents which must be included in notifying the affected data subjects nor the means in notifying them provided under Circular No. 16-03.

Thus, the Commission, in order to resolve the matter deems it proper that HSBC to notify all the affected data subjects and to submit its proof of notification.

WHEREFORE, premises considered, the Hongkong and Shanghai Banking Corporation Limited (HSBC) is hereby **ORDERED** to notify the affected data subjects and to submit proof the same **within fifteen (15) days** from the receipt of this Order directly to the Compliance and Monitoring Division (CMD).

The Commission **DIRECTS** the Compliance and Monitoring Division (CMD) to issue the appropriate orders necessary to evaluate and monitor the completeness of the Hongkong and Shanghai Banking Corporation Limited (HSBC) data breach notification and assess its breach management pursuant to NPC Circular 16-03 (Personal Data Breach Management).

SO ORDERED.

City of Pasay, Philippines.
08 February 2024.

⁴² Post Breach Report of Hongkong and Shanghai Banking Corporation Limited, dated 10 May 2022.

⁴³ Post Breach Report of Hongkong and Shanghai Banking Corporation Limited, dated 10 May 2022, *See*: Annex 2.

SGD
JOHN HENRY D. NAGA
Privacy Commissioner

WE CONCUR:

SGD
LEANDRO ANGELO Y. AGUIRRE
Deputy Privacy Commissioner

SGD
NERISSA N. DE JESUS
Deputy Privacy Commissioner

Copy furnished:

JSS
Data Protection Officer
The Hongkong Shanghai Bank Corporation Limited

COMPLAINTS AND INVESTIGATION DIVISION
COMPLIANCE AND MONITORING DIVISION
ENFORCEMENT DIVISION
GENERAL RECORDS UNIT
National Privacy Commission